

DOCUMENT 07

Security & Compliance

Security principles, authentication, encryption, audit trails, secrets management, regulatory compliance, and incident response.

SCOPE AuthN • Encryption • Audit • AML • SOC 2 • ISO 27001 • IR

SPONSOR Ghana Chamber of Gold Buyers

TECHNOLOGY PARTNER Vanta Technologies Ltd.

CONFIDENTIAL • CHAMBER & VENDOR INTERNAL • AUTHORIZATION DATE 15 AUGUST 2026

TABLE OF CONTENTS

Document 7 — Security & Compliance..... 3

7.1 Security Principles..... 3

7.2 Authentication & Authorization..... 4

 Authentication Mechanism..... 4

 MFA Requirements..... 4

7.3 Data Encryption..... 5

 Encryption at Rest..... 5

 Field-Level Encryption (PII)..... 5

7.4 Audit Trail & Tamper Evidence..... 5

7.5 Secrets Management..... 6

7.6 Compliance Notes..... 6

 Regulatory Landscape..... 6

 Ghana Data Protection Act, 2012 (Act 843) — Selected Controls..... 7

 Bank of Ghana AML/CFT/CPF Directives — Selected Controls..... 8

 SOC 2 Type II + ISO 27001 Roadmap..... 8

7.7 Incident Response..... 9

 Severity Definitions..... 9

 Notification Timelines..... 9

7.8 Audit & Assurance..... 9

 Cross-References..... 10

Right-click the table of contents and select “Update Field” to refresh page numbers after opening in Microsoft Word.

Document 7 — Security & Compliance

This document covers the security architecture, secrets management, compliance notes for relevant regulations (Ghana DPA 2012, BoG AML/CFT, FATF Recommendation 22, OECD Annex II, SOC 2), incident response, and audit & assurance. It is written for security reviewers, compliance officers, and external auditors.

7.1 Security Principles

\#	PRINCIPLE	HOW IMPLEMENTED
S1	Zero Trust — every request authenticated, authorized, inspected	mTLS between services; OAuth/JWT at edge; deny-default network policies in EKS
S2	Defense in Depth — multiple independent controls	WAF + ALB + service-level RBAC + DB row-level security + field-level encryption for PII
S3	Least Privilege — minimum permissions needed	AWS IAM roles scoped per service; Auth0 RBAC with fine-grained scopes; PostgreSQL RLS policies
S4	Audit Everything — every state-changing action logged	Audit Log Service; 7-year retention; hash-anchored chain
S5	Encrypt Everywhere — at rest, in transit, in processing	TLS 1.3 in transit; KMS-managed encryption at rest; field-level encryption for PII
S6	Secure by Default — secure configurations are default	Security linters in CI; pre-commit hooks; CSP-enabled PWA; HSTS preload
S7	Assume Breach — design assumes perimeter will be breached	Network segmentation; per-service accounts; Secrets Manager auto-rotation; canary tokens

7.2 Authentication & Authorization

AUTHENTICATION MECHANISM

LAYER	MECHANISM	PROVIDER
Member-facing PWA	OAuth 2.0 Authorization Code + PKCE; OpenID Connect	Auth0 B2B
Tier 1 machine-to-machine (SAP integration)	OAuth 2.0 Client Credentials; mTLS for high-value buyers	Auth0 B2B
Chamber staff	SAML SSO with Chamber's IdP (Microsoft Entra ID); MFA required	Auth0 federated to Entra ID
Service-to-service (internal)	mTLS via SPIFFE/SPIRE; short-lived (1 hour) JWTs	SPIRE cluster
Partner inbound webhooks	HMAC-SHA256 signature + shared secret + IP allowlisting	Custom (per partner)

MFA REQUIREMENTS

ACTION	MFA REQUIRED
Member login (org.admin)	Step-up: TOTP or passwordless
Member login (org.trader, org.viewer)	Optional
Chamber staff login	Required always
Trade acceptance ≥ US\$100K	Step-up MFA (TOTP or WebAuthn)
Trade acceptance ≥ US\$500K	WebAuthn (hardware key) required
Compliance freeze / SAR filing	WebAuthn required
Production deployments	WebAuthn required for deploying engineer
Production DB access	WebAuthn + just-in-time approval (max 4-hour session)

7.3 Data Encryption

ENCRYPTION AT REST

DATA STORE	ENCRYPTION METHOD	KEY MANAGEMENT
PostgreSQL (RDS)	AES-256, TDE	AWS KMS — customer-managed key (CMK) with annual rotation
Redis (ElastiCache)	AES-256 at-rest encryption	AWS KMS — CMK
Kafka (MSK)	AES-256 in-transit + at-rest	AWS KMS — CMK
S3 documents	AES-256 SSE-KMS	AWS KMS — CMK (separate from RDS for blast-radius isolation)
S3 audit log (WORM)	SSE-KMS + Object Lock (Compliance mode, 7-year)	AWS KMS — CMK (never exposed to app code)
Secrets Manager	AWS-managed + envelope encryption with CMK	AWS KMS — CMK

FIELD-LEVEL ENCRYPTION (PII)

Specific PII columns receive additional application-layer encryption using envelope encryption (AES-256-GCM with per-row data keys, envelope-encrypted with KMS CMK). Includes: members.email, members.phone, members.identity_document_number, organizations.beneficial_owners (JSONB), bank_accounts.account_full_number (tokenized; only last4 in plaintext), assay_certificates.lab_internal_reference.

7.4 Audit Trail & Tamper Evidence

The Audit Log Service is the canonical audit trail. Five design choices ensure tamper evidence:

- Append-only — no UPDATE or DELETE operations exposed; PostgreSQL triggers reject them.
- Hash-anchored chain — each event includes previous_event_hash and current_hash = SHA256(salt + previous_hash + event_payload + timestamp). Salt is stored only in Secrets Manager, never accessible to the application layer at read time.
- Multi-layer storage — live in Kafka compacted topic → warm in S3 with Object Lock (Compliance mode) → cold in S3 in DR region via CRR. Object Lock prevents even root account deletion for the 7-year retention period.
- Continuous verification — background worker recomputes the hash chain every hour. Any break triggers a SEV-1 alert (AuditLogHashChainBreak).

- Independent reviewer access — Chamber Compliance team has direct read access; they can verify hash integrity independently via the public verification API.

7.5 Secrets Management

SECRET TYPE	STORE	ROTATION	ACCESS
Database master password	AWS Secrets Manager	90 days (automatic)	RDS only
Database app password (per-service users)	AWS Secrets Manager	90 days (automatic)	Service IAM role only
Bank API keys	AWS Secrets Manager	Annual or per bank schedule	Escrow Service IAM role only
Auth0 client secrets	AWS Secrets Manager	Annual (manual, Security Eng)	Member Service + Admin app only
Webhook HMAC secrets	AWS Secrets Manager	Quarterly (joint with partner)	Notification Service + partner
Audit log hash salt	AWS Secrets Manager	Never rotated (would invalidate chain)	Audit Log Service writer only
TLS private keys	AWS ACM (managed)	Auto-renewed	ACM only

7.6 Compliance Notes

REGULATORY LANDSCAPE

REGULATION	JURISDICTION	APPLICABILITY
Ghana Data Protection Act, 2012 (Act 843)	Ghana	Applies — platform processes personal data of Ghanaian residents
Bank of Ghana AML/CFT/CPF Directives (2022)	Ghana	Applies — escrow integration, gold trading is regulated financial activity
Ghana Minerals and Mining Act, 2006 (Act 703)	Ghana	Applies — gold licensing, export permits
FATF Recommendation 22 (Precious Metals)	International	Applies — Ghana is a FATF member

REGULATION	JURISDICTION	APPLICABILITY
OECD Due Diligence Guidance (Annex II)	International	Applies — Tier 1 buyers (LBMA refiners) require OECD-aligned due diligence
LBMA Responsible Gold Guidance	International	Indirect — Tier 1 buyers must comply; platform enables their compliance
SOC 2 Type II	International	Applies — vendor-side commitment to Tier 1 buyers
ISO/IEC 27001:2022	International	Target — Year 2 (2029)
PCI-DSS	International	Out of scope — platform does not accept card payments directly

GHANA DATA PROTECTION ACT, 2012 (ACT 843) — SELECTED CONTROLS

REQUIREMENT	HOW WE COMPLY
Lawful basis for processing (§17)	Contract performance (trade execution); legal obligation (AML, sanctions screening); legitimate interest (member directory)
Data subject rights — access, rectification, erasure, portability (§33–36)	Self-service portal for access + rectification; erasure honored unless legal retention (AML = 7 years); JSON export via API
Cross-border transfer (§84)	Lawful basis documented; Standard Contractual Clauses (SCCs) with AWS; transfer impact assessment completed; primary region af-west-1
Data breach notification (§38)	Notification to Data Protection Commission within 72 hours; affected subjects notified without undue delay
Data Protection Officer (§24)	Vendor-side DPO + Chamber-side DPO (Efua Boateng)
Retention	Personal data retained 7 years post-account-closure (AML requirement); thereafter securely destroyed

BANK OF GHANA AML/CFT/CPF DIRECTIVES — SELECTED CONTROLS

REQUIREMENT	HOW WE COMPLY
Customer Due Diligence (CDD)	Three-tier CDD: Simplified (Tier 2 low-value), Standard (default), Enhanced (PEPs, high-risk jurisdictions, high-value trades ≥ US\$100K)
Beneficial ownership identification	Required at onboarding for all organizations. Beneficial owners defined as ≥ 10% ownership or control. Verified against Ghana BO Registry + Chamber registry
PEP screening	All members + beneficial owners screened against PEP database. PEP status triggers Enhanced Due Diligence
Sanction list screening	Daily refresh of OFAC SDN, EU consolidated, UN Security Council, Ghana MoF. Re-screen on every trade event
Suspicious Transaction Reporting	Compliance Officer files SAR with FIC within 24 hours of detection via platform-integrated workflow
Record keeping (\$30)	All trade + KYC records retained 7 years; tamper-evident audit log; retrievable within 24 hours for regulatory request

SOC 2 TYPE II + ISO 27001 ROADMAP

FRAMEWORK	STATUS	TARGET
SOC 2 Type I	In progress	Q1 2028 — readiness Q3 2027; controls operational Q4 2027
SOC 2 Type II	In progress	Q3 2028 — 12-month observation from Type I (Charter Objective \#5)
ISO 27001:2022	Planned	Year 2 (2029) — gap assessment Q2 2028; certification audit Q4 2028
ISO 27701 (Privacy)	Planned	Year 3 (2029) — build on ISO 27001

7.7 Incident Response

SEVERITY DEFINITIONS

SEVERITY	DEFINITION	RESPONSE TIME
SEV-1	Production down; data loss; trade-blocking; security breach	5 min ack, 15 min mitigation start; page on-call + Security Eng + Vendor PM; notify Chamber PMO within 15 min
SEV-2	Significant degradation; trade-friction; non-critical path broken	30 min ack, 2 hr mitigation; page on-call SRE; notify Chamber PMO within 1 hr
SEV-3	Minor issue; workaround exists	Next business day
SEV-4	Cosmetic; non-impactful	Backlog

NOTIFICATION TIMELINES

TRIGGER	RECIPIENT	TIMELINE
Personal data breach (DPA §38)	Ghana Data Protection Commission	Within 72 hours of awareness
Personal data breach (high risk)	Affected data subjects	Without undue delay after DPC notification
Trade data breach / suspicious trading	Bank of Ghana (Financial Stability Dept.)	Within 24 hours
Trade data breach (material to Chamber)	Chamber Executive Council	Within 4 hours
Material security incident affecting Tier 1 buyers	Affected Tier 1 buyer's compliance team	Within 24 hours (per MSA)
SOC 2 reportable incident	SOC 2 auditor	At next quarterly audit window

7.8 Audit & Assurance

AUDIT	FREQUENCY	OWNER
Access review (IAM + Auth0)	Quarterly	Security Eng

AUDIT	FREQUENCY	OWNER
Secrets access review	Quarterly	Security Eng
Change management review	Quarterly	Vendor PM
DR test (staging)	Quarterly	SRE
DR test (prod)	Annually	SRE + Vendor PM + Chamber PMO
Audit log integrity test	Weekly (automated)	Compliance Eng
Penetration test	Annually + on major releases	Security Eng + Vendor PM
AML compliance audit	Annually (third-party)	Compliance Officer (Chamber)
Privacy impact assessment	Annually + on material change	DPO

CROSS-REFERENCES

This document suite is designed as a coherent whole. The Charter's objectives (Doc 1 §3.2) flow into User Personas (Doc 2), which drive User Success Journeys (Doc 3), which inform System Architecture (Doc 4), which is operationalized by User/System Flows (Doc 5), supported by DevOps runbooks (Doc 6), and governed by Security & Compliance controls (Doc 7). Specific cross-references appear at the end of each document. The full suite — including the master README with reading paths for executives, PMs, architects, engineers, and auditors — is available alongside this Word document as an animated HTML presentation and as the original Markdown source.

> This documentation suite is the confidential, proprietary work product of Vanta Technologies Ltd. and the Ghana Chamber of Gold Buyers. Distribution is restricted to authorized project stakeholders. Personal names in this document are placeholders pending confirmation by the project's joint Change Control Board.